

Script video final - Daylight / Cyber Trust

Support de lecture pour la video : intro, architecture, Wazuh, dashboards, playbooks, limites et conclusion.

Format

Duree cible : 15 a 18 minutes.

Important : chaque personne doit parler et afficher son nom au moins une fois.

0. Introduction - Kilyan FELIX - 00:00 a 01:30

Ecran a montrer : Presentation_Daylight_CyberTrust.pptx

Bonjour, nous sommes l'equipe Cyber Trust. Nous presentons notre projet de SOC externalise pour Daylight, un reseau fictif de centres d'audioprothesistes.

Le besoin de Daylight est de centraliser les evenements de securite, detecter les incidents importants, superviser plusieurs sources de logs et fournir des tableaux de bord exploitables.

Notre demonstrateur repose sur quatre axes : une architecture reseau segmentee avec pfSense, un SIEM Wazuh centralise, des regles de detection avec dashboards, et des playbooks de reponse aux incidents.

Dans l'equipe, Yvan FOCSA presente l'architecture et pfSense. Youssef GUERNIOU presente Wazuh, les agents, la collecte et le RBAC. Je presente la detection, la qualification et les dashboards. Mahamadou DIACOUMBA presente l'exploitation du lab, les playbooks, les procedures et le REX.

Transition : Je laisse Yvan presenter l'architecture.

1. Architecture et pfSense - Yvan FOCSA - 01:30 a 04:30

Ecrans a montrer :

- YVAN/01_SCHEMAS_A_REFAIRE/01_architecture_globale_daylight_cybertrust.drawio
- YVAN/05_CAPTURES_REELLES_PFSENSE/CAP-29_pfsense-dashboard-reel.png
- YVAN/05_CAPTURES_REELLES_PFSENSE/CAP-32_pfsense-rules-lan-reelles.png
- YVAN/05_CAPTURES_REELLES_PFSENSE/CAP-34_pfsense-block-live.png
- YVAN/05_CAPTURES_REELLES_PFSENSE/CAP-35_pfsense-syslog-wazuh-reel.png
- YVAN/05_CAPTURES_REELLES_PFSENSE/CAP-36_wazuh-pfsense-alertes-reelles.png

Ma partie concerne l'architecture de la solution. L'objectif est de proposer a Daylight une architecture claire, securisee et industrialisable.

Le principe principal est la segmentation. On separe les postes utilisateurs, les serveurs internes, l'application exposee en DMZ, l'administration et la zone SOC.

La cible est structuree autour de cinq zones : USERS en 10.10.10.0/24, SERVERS en 10.10.20.0/24, DMZ en 10.10.30.0/24, MGMT en 10.10.40.0/24 et SOC en 10.10.50.0/24.

pfSense joue le role de firewall et de passerelle. Il applique une logique de moindre privilege : on autorise uniquement les flux necessaires et on bloque le reste.

Sur la capture pfSense, on voit le firewall pfsense-fw-01.daylight.local, avec un WAN en 192.168.5.128 et un LAN d'administration en 10.10.40.1. Dans cette VM de demonstration, le LAN sert a administrer pfSense. Les autres zones sont representees par les alias, les regles et le schema cible.

Les alias pfSense representent les objets reseau Daylight : USERS_SUBNET, SERVERS_SUBNET, DMZ_SUBNET, ADMIN_SUBNET, SOC_SUBNET, SOC_WAZUH, DAYLIGHT_APP et les resolvers DNS autorises.

Les regles LAN montrent le filtrage concret. On autorise le DNS vers DNS_ALLOWED, l'application Daylight en HTTPS vers DAYLIGHT_APP, puis on bloque les flux utilisateurs vers SERVERS_SUBNET, ADMIN_SUBNET et SOC_SUBNET. La navigation web standard reste autorisee sur 80 et 443.

Sur WAN, aucune regle entrante n'est ouverte. pfSense applique donc un refus entrant par default, ce qui limite l'exposition externe.

La capture des logs firewall montre que pfSense bloque bien du trafic, notamment avec la regle Block users to admin zone. Cela prouve que les regles ne sont pas seulement documentees : elles generent des logs exploitables.

Enfin, pfSense est configure pour envoyer ses logs vers Wazuh en syslog UDP sur 10.10.50.10:514. Dans Wazuh, les alertes 110010 et 110020 montrent respectivement du trafic WAN bloque et une tentative de mouvement lateral vers MGMT.

Phrase importante : pfSense n'apparait pas dans la page Agents de Wazuh, car ce n'est pas un agent Wazuh. Il apparait dans les evenements de securite via syslog.

Transition : Maintenant que l'architecture filtre et journalise les flux, Youssef va presenter Wazuh.

2. Wazuh, collecte, alertes et RBAC - Youssef GUERNIOU - 04:30 a 08:30

Ecrans a montrer :

- Wazuh <https://localhost>
- Agents Wazuh
- Recherche SSH
- Recherche pfSense
- Capture ou preuve RBAC

Je presente la partie SIEM. Nous avons retenu Wazuh, car c'est une solution open-source qui permet de centraliser des logs, collecter des agents, recevoir du syslog, appliquer des regles de detection et afficher les alertes dans une interface web.

Le lab Wazuh est deploye en single-node Docker avec trois composants : Wazuh Manager, Wazuh Indexer et Wazuh Dashboard. Ce choix est adapte a une demonstration, car il rend l'environnement reproductible.

La collecte couvre plusieurs sources : un serveur Linux serveur-01, un endpoint documente poste-01, les logs applicatifs Daylight et les logs pfSense en syslog.

Sur la page Agents, on voit serveur-01 actif. Pour ce serveur, nous avons installe l'agent Wazuh, active SSH et rsyslog, puis ajoute le suivi de /var/log/auth.log.

Ensuite, nous avons simule des echecs de connexion SSH. Wazuh detecte ces evenements avec des regles comme 5503, 5551, 5763 et la preuve historique 5712 dans la documentation SIEM.

Pour pfSense, les logs arrivent via syslog. La recherche rule.id:110010 OR rule.id:110020 OR pfsense-fw-01 permet de voir les alertes reseau. La regle 110010 correspond au trafic entrant bloque sur WAN et 110020 correspond a une tentative vers une zone sensible.

Nous avons aussi mis en place le RBAC. Il existe un compte admin avec acces complet, puis des comptes analyste et supervision rattaches a un role de lecture seule. Cela repond a l'exigence d'une interface segmentee par roles.

Transition : Je laisse Kilyan presenter la qualification des alertes et les dashboards.

3. Detection, qualification et dashboards - Kilyan FELIX - 08:30 a 11:30

Ecrans a montrer :

- Dashboards_Offline/daylight_soc_dashboard.html
- captures dashboard technique/executif
- matrice de qualification

Ma partie consiste a transformer les alertes techniques en information exploitable pour le SOC et pour le client.

Une alerte brute n'est pas suffisante. Il faut lui attribuer une severite, un contexte, un niveau de priorite, un SLA de traitement et une procedure d'escalade.

Nous avons defini une matrice de qualification. Par exemple, un acces anormal a un dossier patient avec la regle 100120 est critique, car il concerne des donnees sensibles. Une brute force SSH est haute ou critique selon le volume et la presence d'une connexion reussie. Une alerte pfSense 110020 est critique si elle vise MGMT ou une zone serveur.

Le dashboard technique est fait pour les analystes. Il affiche les alertes par severite, par source, par regle et par chronologie. Il permet de prioriser rapidement les investigations.

Le dashboard executif est fait pour Daylight. Il presente une vision plus lisible : volume d'alertes, alertes critiques, repartition par site et tendance globale.

Cette double lecture repond au cahier des charges : un dashboard operationnel pour les analystes et un reporting simple pour le client.

Transition : Une fois les alertes qualifiees, il faut savoir comment reagir. Mahamadou presente les procedures et playbooks.

4. Exploitation, runbooks, playbooks et REX - Mahamadou DIACOUMBA - 11:30 a

Ecrans a montrer :

- 22_EXPLOITATION_VM_RUNBOOK_REX.md
- 03_PLAYBOOKS_PROCEDURES_REX.md
- preflight ou rapport de relance

Ma partie concerne l'exploitation du lab et la reponse aux incidents. L'objectif est que le demonstrateur soit relancable et que chaque alerte importante ait une procedure associee.

Le lab utilise des conteneurs Docker pour Wazuh et serveur-01, et une VM pfSense pour le firewall. Les procedures indiquent comment redemarrer les composants apres extinction du poste.

Pour Wazuh, on verifie que Docker est lance, que les conteneurs Manager, Indexer et Dashboard sont actifs, puis que l'interface https://localhost repond.

Pour serveur-01, on relance le conteneur et les services utiles : rsyslog, SSH et l'agent Wazuh.

Nous avons aussi documente des playbooks. Pour une brute force SSH, on verifie la source, le compte vise, le nombre d'echecs, puis on cherche une eventuelle connexion reussie. Si l'incident est confirme, on bloque la source, on protege le compte et on conserve les preuves.

Pour un acces anormal a un dossier patient, on verifie l'utilisateur, le dossier concerne, le site Daylight et l'heure. Comme cela peut toucher des donnees sensibles, on escalade vers le referent client et le DPO si necessaire.

Le REX permet de documenter ce qui s'est passe, ce qui a bien fonctionne et ce qui doit etre ameliore.

Transition : Je repasse la parole a Yvan pour les limites et l'industrialisation.

5. Limites, industrialisation et conclusion - Yvan puis equipe - 14:30 a 17:00

Ecrans a montrer :

- schema cible
- rapport groupe
- checklist finale

Yvan :

Le demonstrateur prouve la faisabilite : segmentation, filtrage, collecte, detection, dashboards et procedures.

Il faut cependant distinguer le lab de la production. Dans le lab, Wazuh tourne en single-node Docker, et pfSense est deploye en VM avec une interface WAN et une interface LAN d'administration. Les autres zones sont representees par les alias, les regles, les logs et les schemas.

En production, chaque zone serait portee par des VLAN ou par des interfaces dediees pfSense. Wazuh serait dimensionne avec des composants separes, une politique de retention, des sauvegardes et une supervision des composants.

Kilyan ou conclusion equipe :

Pour conclure, Cyber Trust propose a Daylight une solution de SOC externalise qui combine prevention et detection. pfSense reduit la surface d'attaque et journalise les flux sensibles. Wazuh centralise les evenements et declenche les alertes. Les dashboards rendent l'information exploitable. Les playbooks structurent la reponse aux incidents.

Le projet repond donc aux exigences principales : architecture technique, demonstrateur operationnel, collecte multi-source, SIEM open-source, alertes, dashboards, procedures, reporting et video de demonstration.

Merci pour votre attention.

Phrases de secours

Si pfSense ne repond plus :

La configuration pfSense a ete capturee et integree au dossier. La preuve importante est la combinaison des regles firewall, des logs pfSense et des alertes Wazuh 110010 et 110020.

Si pfSense n'apparait pas dans Agents :

C'est normal. pfSense n'est pas un agent Wazuh. Il envoie ses logs via syslog UDP 514.

Si poste-01 n'apparait pas :

Dans le live actuel, poste-01 n'est pas forcement reconnecte. Sa preuve endpoint est documentee dans le dossier SIEM. Le live montre serveur-01, pfSense et les alertes associees.

Si on vous demande si c'est de la production :

Non, c'est un MVP demonstrateur. La production demanderait un pilote, des VLAN reels, une architecture Wazuh dimensionnee, des sauvegardes, une retention et une supervision complete.